

Results Summary

C

4

H

28

M

16

Shield

48

Table of Contents

Filtered By

3

Scan Information

3

Project & Scan Tags

3

Scan Results Overview

4

By Scanner

4

By Status

4

By Severity

4

By State

4

Results Distribution By Status

4

Results Distribution By State

4

By Language

5

By Technology

5

By Package

5

By SAST Vulnerability

6

Top 10 SAST Vulnerabilities

6

Top 10 SAST Vulnerable Files

6

5 Oldest SAST Vulnerabilities

7

SAST Vulnerabilities

8

By Severity

8

SAST Scan Results

8

Stored_XSS

8

Cleartext_Submission_of_Sensitive_Information

9

Uncontrolled_Memory_Allocation

10

Stored_Absolute_Path_Traversal

11

Missing_HSTS_Header

12

Missing_HSTS_Header

12

IaC Security Vulnerabilities

14

By Severity

14

IaC Security Scan Results

14

SCA Vulnerabilities

15

By Severity

15

SCA Scan Results

15

Maven-org.eclipse.jetty:jetty-http-12.1.11

15

Maven-org.bouncycastle:bcprov-jdk18on-1.84

15

Maven-tools.jackson.core:jackson-databind-3.2.1

19

Maven-commons-collections:commons-collections-3.2.2

20

Maven-org.eclipse.jetty.websocket:jetty-websocket-core-common-12.1.11

21

Maven-org.springframework:spring-beans-7.0.8

21

Maven-org.springframework:spring-expression-7.0.8

22

Maven-org.springframework:spring-web-7.0.8

22

Maven-org.apache.ant:ant-1.10.17

23

Maven-org.bouncycastle:bcpg-jdk18on-1.84

24

Maven-org.bouncycastle:bcpkix-jdk18on-1.84

25

Maven-org.springframework.security:spring-security-core-7.1.0

27

Maven-org.springframework.security:spring-security-crypto-7.1.0

28

Maven-commons-lang:commons-lang-2.6

28

SAST Resolved Vulnerabilities 29

Categories 30

ASA Premium 30

ASD STIG 6.1 30

Base Preset 30

CWE top 25 30

FISMA 2014 30

MOIS(KISA) Secure Coding 2021 30

NIST SP 800-53 31

OWASP ASVS 31

OWASP Mobile Top 10 2024 31

OWASP Top 10 2013 31

OWASP Top 10 2017 32

OWASP Top 10 2021 32

OWASP Top 10 2025 32

OWASP Top 10 API 33

OWASP Top 10 API 2023 33

PCI DSS v3.2.1 33

PCI DSS v4.0 33

SANS top 25 33

Top Tier 34

Vulnerability Details 35

Stored_XSS 35

Cleartext_Submission_of_Sensitive_Information 35

Uncontrolled_Memory_Allocation 36

Stored_Absolute_Path_Traversal 36

Missing_HSTS_Header 37

Missing_HSTS_Header 38

Filtered By

Severity:   

Excluded: Low, Information

Result State: To Verify, Confirmed, Urgent

Excluded: Not Exploitable, Proposed Not Exploitable

Status: New, Recurrent

Excluded: None

Scanners: SAST, IaC Security, SCA, API Security, Container Security

Excluded: None

Queries: [Link](#)

Results limited to: 10000

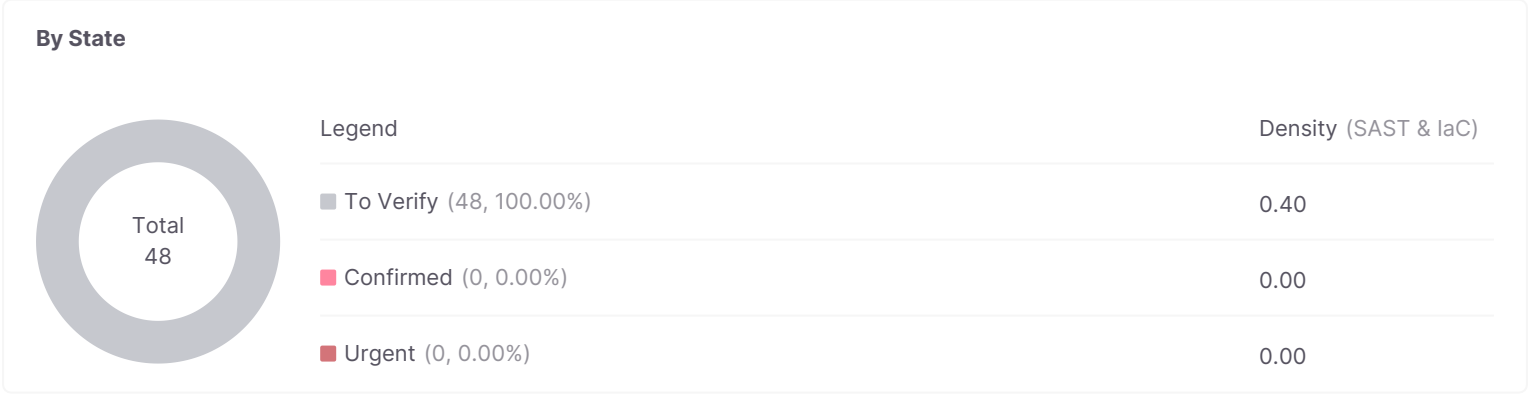
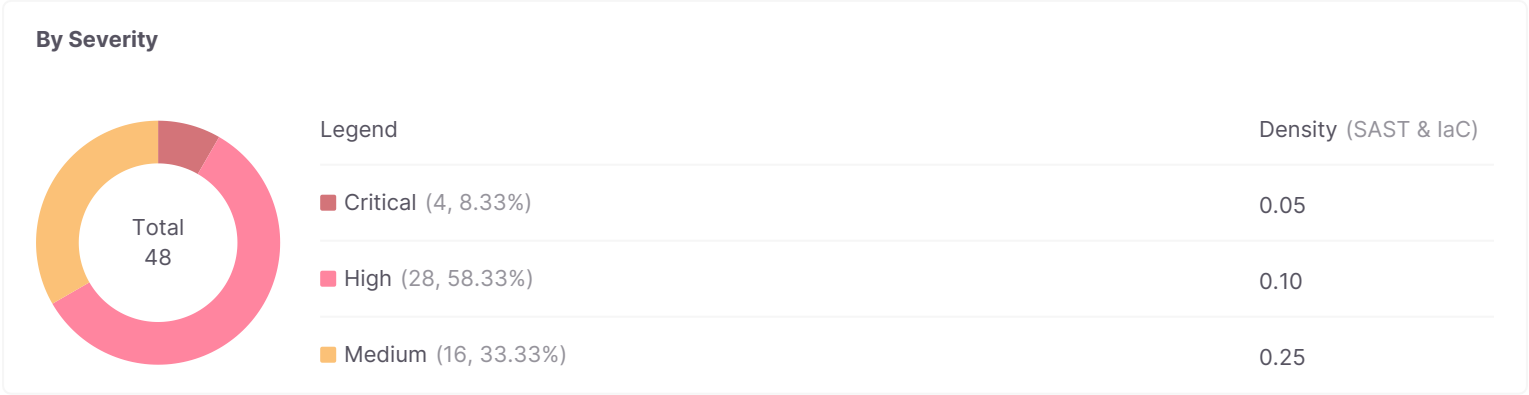
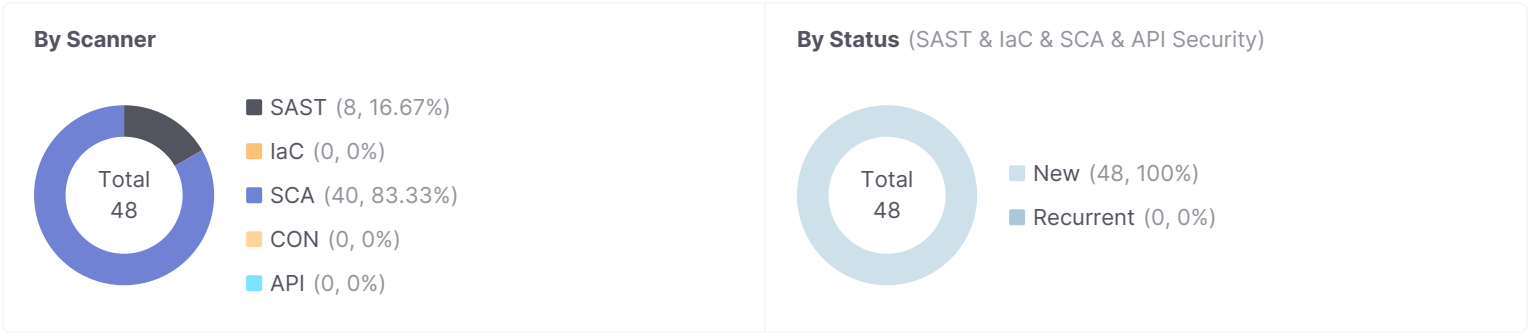
Scan Information

- Project Name: octane-orchestrator - Scan Id: b60831d9-e7da-41dd-9da5-0d7827fc7374 - Scan Duration: 0h 2m 10s - Preset: All - LOC Scanned: 20019 - SAST: 20019 - IaC: 0 - Files Scanned: 84 - SAST: 84 - IaC: 0 - Density: 0.4 - SAST: 0.4 - IaC: 0 - Initiator: org_admin - Online Results: Link	- Source Origin: zip - Main Branch: N/A - Scan Type: Full Scan - Scanned Branch Name: main - Groups: None - Scanner Status: - SAST: Completed - SCA: Completed - API Security: Completed - Container Security: Completed - IaC: Completed
---	--

Project & Scan Tags

Project Tags:
None
Scan Tags:
None

Scan Results Overview

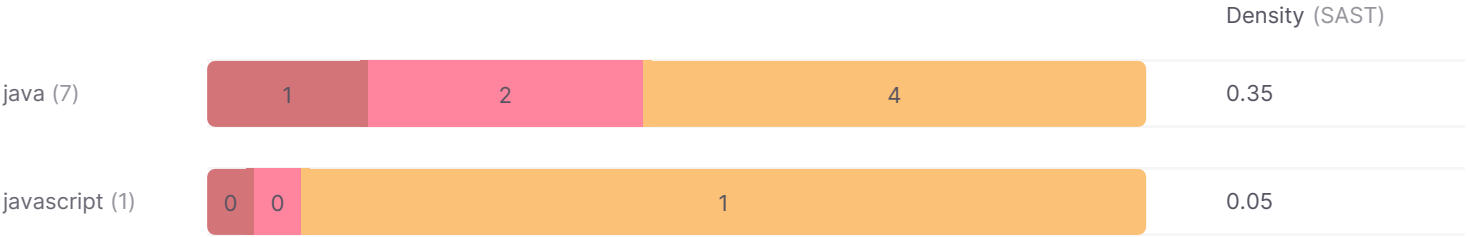


Results Distribution By Status				
Status	C	H	M	Total
New	4	28	16	48
Recurrent	0	0	0	0
Total	4	28	16	48

Results Distribution By State				
State	C	H	M	Total
To Verify	4	28	16	48

Confirmed	0	0	0	0
Urgent	0	0	0	0
Total	4	28	16	48

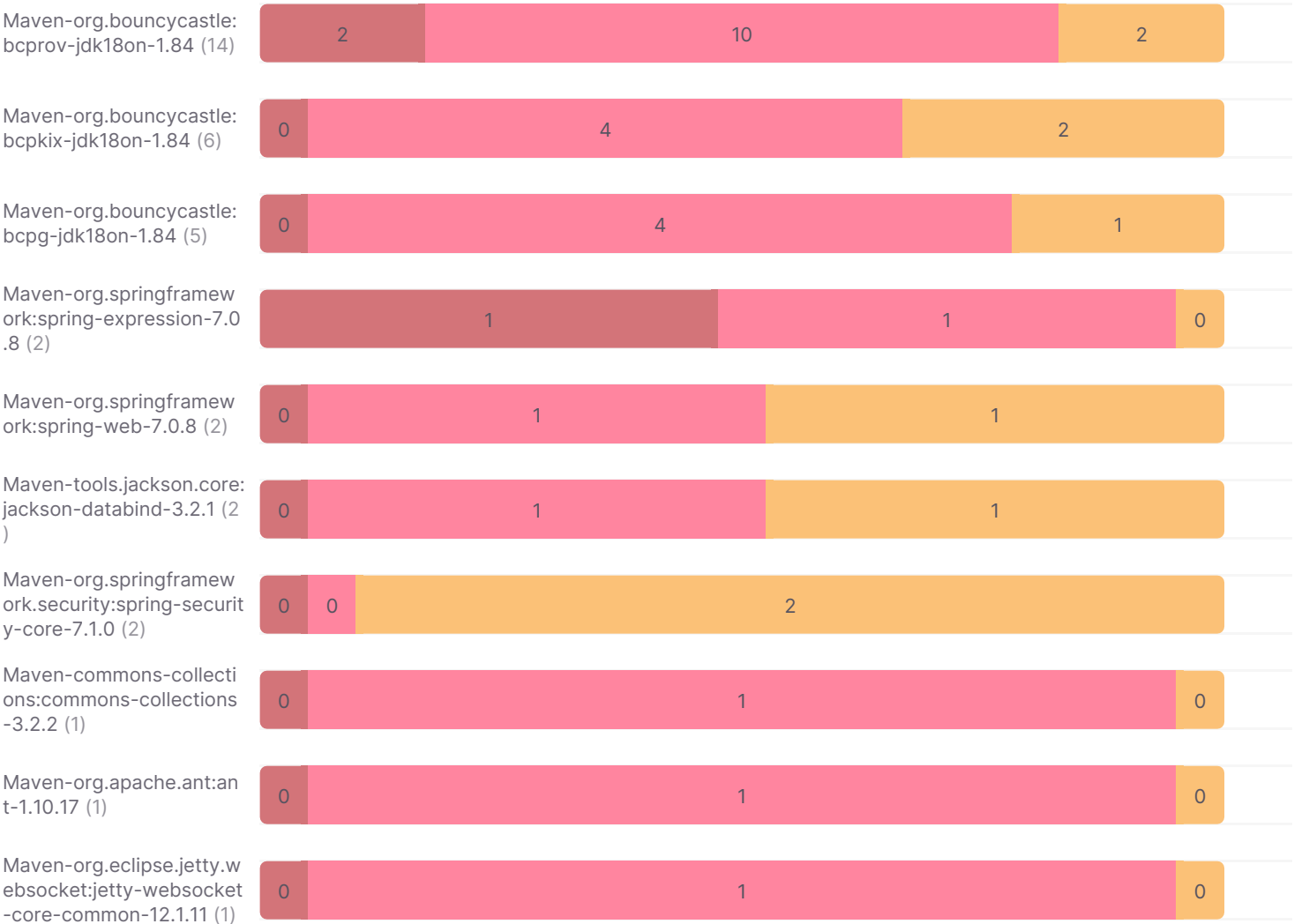
By Language (SAST)

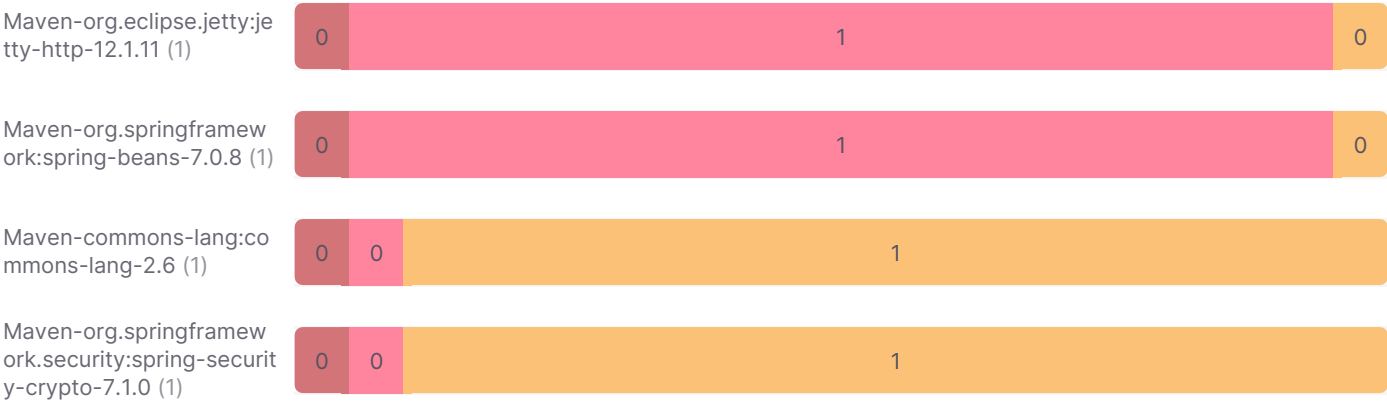


By Technology (IaC)

No data to show

By Package (SCA)

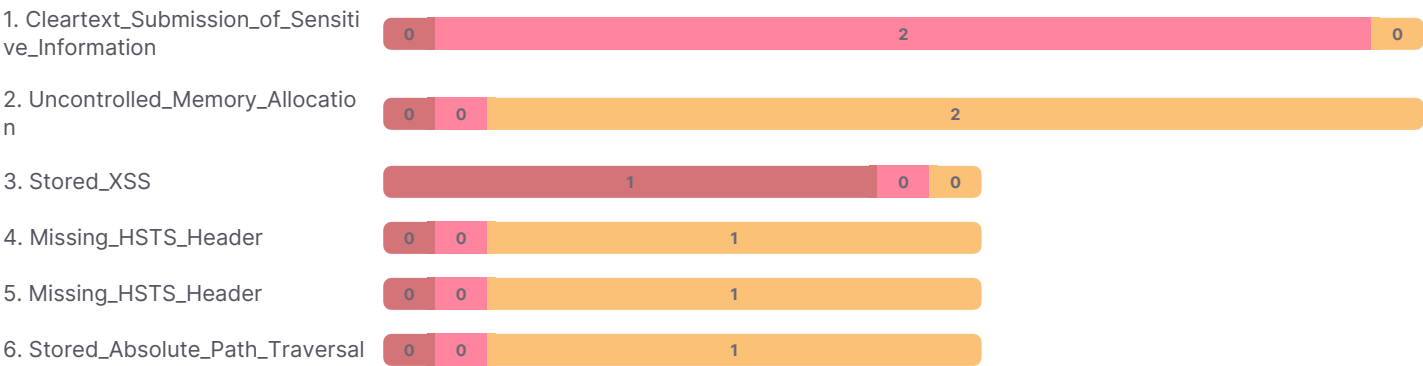




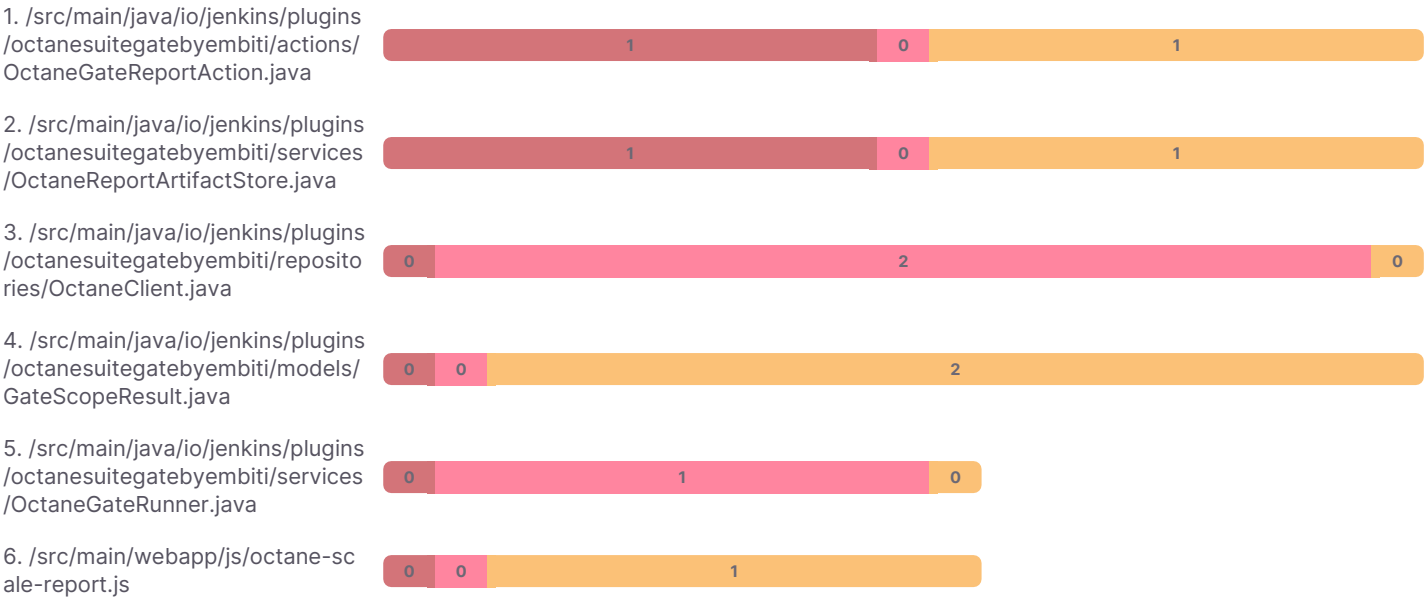
By SAST Vulnerability

	Vulnerability Type			
	Stored_XSS In 2 Files	1	0	0
	Cleartext_Submission_of_Sensitive_Information In 2 Files	0	2	0
	Uncontrolled_Memory_Allocation In 1 Files	0	0	2
	Missing_HSTS_Header In 1 Files	0	0	1
	Missing_HSTS_Header In 1 Files	0	0	1
	Stored_Absolute_Path_Traversal In 1 Files	0	0	1
	Total In 6 Files	1	2	5

Top 10 SAST Vulnerabilities (8/6 Vulnerable files)



Top 10 SAST Vulnerable Files (6/84 Files)



5 Oldest SAST Vulnerabilities by severity



1. Stored_XSS 0 days

1. Cleartext_Submission_of_Sensitive_Information 0 days

1. Missing_HSTS_Header 0 days

2. Stored_Absolute_Path_Traversal 0 days

3. Uncontrolled_Memory_Allocation 0 days

SAST Vulnerabilities

By Severity



SAST Scan Results (8)

Stored_XSS (Type)

Query Path: [Java/Java_Critical_Risk/Stored_XSS](#)

CWE Id: [79](#)

Total results: [1](#)

Description: The method [@DestinationMethod](#) embeds untrusted data in generated output with [@DestinationElement](#), at line [@DestinationLine](#) of [@DestinationFile](#). This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page. The attacker would be able to alter the returned web page by saving malicious data in a data-store ahead of time. The attacker's modified data is then read from the database by the [@SourceMethod](#) method with [@SourceElement](#), at line [@SourceLine](#) of [@SourceFile](#). This untrusted data then flows through the code straight to the output web page, without sanitization. This can enable a Stored Cross-Site Scripting (XSS) attack.

Category:

- ASA Premium: [ASA Premium](#)
- ASD STIG 6.1: [APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting \(XSS\) vulnerabilities.](#)
- Base Preset: [Base Preset](#)
- CWE top 25: [CWE top 25](#)
- FISMA 2014: [System And Information Integrity](#)
- MOIS(KISA) Secure Coding 2021: [MOIS\(KISA\) Verification and representation of input data](#)
- NIST SP 800-53: [SI-15 Information Output Filtering \(PO\)](#)
- OWASP ASVS: [V05 Validation, Sanitization and Encoding](#)
- OWASP Mobile Top 10 2024: [M4: Insufficient Input/Output Validation](#)
- OWASP Top 10 2013: [A3-Cross-Site Scripting \(XSS\)](#)
- OWASP Top 10 2017: [A7-Cross-Site Scripting \(XSS\)](#)
- OWASP Top 10 2021: [A3-Injection](#)
- OWASP Top 10 2025: [A05-Injection](#)
- PCI DSS v3.2.1: [PCI DSS \(3.2.1\) - 6.5.7 - Cross-site scripting \(XSS\)](#)
- PCI DSS v4.0: [PCI DSS \(4.0\) - 6.2.4 Vulnerabilities in software development](#)
- SANS top 25: [SANS top 25](#)
- Top Tier: [Top Tier](#)

Result 1 of 1

[Critical](#) • [Link](#) • [New](#) • [To Verify](#) • Similarity Id: [1088577585](#) • Found First: [16 Sep, 2026](#) • Found Last: [16 Sep, 2026](#)
First Scan ID: [b60831d9-e7da-41dd-9da5-0d7827fc7374](#)

Source	Destination
File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/services/OctaneReportArtifactStore.java	File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/actions/OctaneGateReportAction.java
Method: readArtifact	Method: doData
Element: readAllBytes	Element: write

Code Snippets

166 | return Files.readAllBytes(path);

340 | response.getOutputStream().write(body);

Cleartext_Submission_of_Sensitive_Information (Type)

Query Path: Java/Java_High_Risk/Cleartext_Submission_of_Sensitive_Information

CWE Id: 319

Total results: 2

Description: Potentially sensitive personal information @SourceElement, at line @SourceLine of @SourceFile, is sent over an unsecured channel via @DestinationElement, in @DestinationMethod of @DestinationFile, line @DestinationLine. This could expose this personal data and allow it to be stolen.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002460 - CAT II The application must maintain the confidentiality and integrity of information during preparation for transmission.
- FISMA 2014: Configuration Management
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Security Functions
- NIST SP 800-53: SC-8 Transmission Confidentiality and Integrity (P1)
- OWASP ASVS: V09 Communication
- OWASP Mobile Top 10 2024: M5: Insecure Communication
- OWASP Top 10 2013: A6-Sensitive Data Exposure
- OWASP Top 10 2017: A3-Sensitive Data Exposure
- OWASP Top 10 2021: A2-Cryptographic Failures
- OWASP Top 10 2025: A04-Cryptographic Failures
- OWASP Top 10 API: API7-Security Misconfiguration
- OWASP Top 10 API 2023: API10-Unsafe Consumption of APIs
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.4 - Insecure communications
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25

Result 1 of 2

High • Link • New • To Verify • Similarity Id: 1090729939 • Found First: 16 Sep, 2026 • Found Last: 16 Sep, 2026
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

Source

File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/services/OctaneGateRunner.java

Method: PollingSession

Element: credentials

Destination

File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/repositories/OctaneClient.java

Method: authenticate

Element: build

Code Snippets

150 | credentials.getUsername(),

117 | .build();

Result 2 of 2

High • Link • New • To Verify • Similarity Id: -1734211326 • Found First: 16 Sep, 2026 • Found Last: 16 Sep, 2026
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

Source File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/repositories/OctaneClient.java Method: authenticate Element: clientSecret	Destination File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/repositories/OctaneClient.java Method: authenticate Element: build
Code Snippets 110 payload.put("client_secret", clientSecret); 117 .build();	

Uncontrolled_Memory_Allocation (Type)

Query Path: Java/Java_Medium_Threat/Uncontrolled_Memory_Allocation

CWE Id: 789

Total results: 2

Description: Method @DestinationMethod of the application allocates an arbitrary amount of memory for @DestinationElement, in @DestinationFile line @DestinationLine, based on user input @SourceElement from @SourceFile:@SourceLine. This could enable an attacker to cause the application to consume a large amount of memory.

Category:

- OWASP Top 10 API 2023: API4-Unrestricted Resource Consumption

Result 1 of 2

Medium • Link • New • To Verify • Similarity Id: 395206107 • Found First: 16 Sep, 2026 • Found Last: 16 Sep, 2026
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

Source File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/models/GateScopeResult.java Method: toMap Element: MAX_VALUE	Destination File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/models/GateScopeResult.java Method: toMap Element: detailCount
Code Snippets 116 return toMap(Integer.MAX_VALUE); 131 List<String> runIds = new ArrayList<>(detailCount);	

Result 2 of 2

Medium • Link • New • To Verify • Similarity Id: -357880957 • Found First: 16 Sep, 2026 • Found Last: 16 Sep, 2026
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

Source	Destination
File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/models/GateScopeResult.java Method: toMap Element: MAX_VALUE	File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/models/GateScopeResult.java Method: toMap Element: detailCount
Code Snippets	
116 return toMap(Integer.MAX_VALUE);	
132 List<Map<String, Object>> runMaps = new ArrayList<>(detailCount);	

Stored_Absolute_Path_Traversal (Type)

Query Path: Java/Java_Medium_Threat/Stored_Absolute_Path_Traversal

CWE Id: 36

Total results: 1

Description: Method @SourceMethod at line @SourceLine of @SourceFile gets dynamic data from the @SourceElement element. This element's value then flows through the code and is eventually used in a file path for local disk access in @DestinationMethod at line @DestinationLine of @DestinationFile. This may cause a Path Traversal vulnerability.

Category:

- CWE top 25: [CWE top 25](#)
- MOIS(KISA) Secure Coding 2021: [MOIS\(KISA\) Verification and representation of input data](#)
- OWASP ASVS: [V12 Files and Resources](#)
- OWASP Mobile Top 10 2024: [M4: Insufficient Input/Output Validation](#)
- OWASP Top 10 2013: [A4-Insecure Direct Object References](#), [A4-Insecure Direct Object References](#)
- OWASP Top 10 2017: [A5-Broken Access Control](#)
- OWASP Top 10 2021: [A1-Broken Access Control](#), [A3-Injection](#)
- OWASP Top 10 2025: [A01-Broken Access Control](#)
- PCI DSS v3.2.1: [PCI DSS \(3.2.1\) - 6.5.8 - Improper access control](#)
- PCI DSS v4.0: [PCI DSS \(4.0\) - 6.2.4 Vulnerabilities in software development](#)
- SANS top 25: [SANS top 25](#)

Result 1 of 1

Medium • [Link](#) • New • To Verify • Similarity Id: 23022973 • Found First: 16 Sep, 2026 • Found Last: 16 Sep, 2026
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

Source	Destination
File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/services/OctaneReportArtifactStore.java Method: readArtifact Element: path	File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/services/OctaneReportArtifactStore.java Method: readArtifact Element: readAllBytes
Code Snippets	
166 return Files.readAllBytes(path);	

Missing_HSTS_Header (Type)

Query Path: Java/Java_Medium_Threat/Missing_HSTS_Header

CWE Id: 346

Total results: 1

Description: The web-application does not define an HSTS header, leaving it vulnerable to attack.

Category:

- ASA Premium: ASA Premium
- Base Preset: Base Preset
- OWASP ASVS: V14 Configuration
- OWASP Top 10 2021: A7-Identification and Authentication Failures
- OWASP Top 10 2025: A07-Authentication Failures
- OWASP Top 10 API 2023: API8-Security Misconfiguration
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 1

Medium • Link • New • To Verify • Similarity Id: -1335694275 • Found First: 16 Sep, 2026 • Found Last: 16 Sep, 2026
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

Source	Destination
File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/actions/OctaneGateReportAction.java	File Name: /src/main/java/io/jenkins/plugins/octanesuitegatebyembiti/actions/OctaneGateReportAction.java
Method: doData	Method: doData
Element: write	Element: write

Code Snippets

340 | response.getOutputStream().write(body);

Missing_HSTS_Header (Type)

Query Path: JavaScript/JavaScript_Medium_Threat/Missing_HSTS_Header

CWE Id: 346

Total results: 1

Description: The web-application does not define an HSTS header, leaving it vulnerable to attack.

Category:

- ASA Premium: ASA Premium
- Base Preset: Base Preset
- OWASP ASVS: V14 Configuration
- OWASP Top 10 2021: A7-Identification and Authentication Failures
- OWASP Top 10 2025: A07-Authentication Failures
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 1

Medium • Link • New • To Verify • Similarity Id: -204149017 • Found First: 16 Sep, 2026 • Found Last: 16 Sep, 2026
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

SourceFile Name: `/src/main/webapp/js/octane-scale-report.js`Method: `Lambda`Element: `json`**Destination**File Name: `/src/main/webapp/js/octane-scale-report.js`Method: `Lambda`Element: `json`**Code Snippets**

```
340 | return response.json();
```

IaC Security Vulnerabilities

No data to show

IaC Security Scan Results (0)

No data to show

SCA Vulnerabilities

By Severity



SCA Scan Results (40 Results)

Maven-org.eclipse.jetty:jetty-http-12.1.11 (1 Result)

Package Name: org.eclipse.jetty:jetty-http
Version: 12.1.11
Total Results: 1

Category: [CWE-444](#)
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: mNAF4+3UEZjJgmyMVM4VRcST2saPe+um8rJIWdnZ/88=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-19203
Description: A client may issue specially crafted HTTP/1.1 chunked requests to a Jetty server that cause Jetty and an intermediary proxy to interpret different request boundaries, potentially resulting in HTTP request smuggling. All versions prior to 12.0.38 and 12.1.x prior to 12.1.12 are affected. This is caused by Jetty accepting a lone LF character as a terminator in parts of chunked request parsing. Depending on the Jetty version and configured HTTP compliance mode, this may occur in chunk extensions, chunk data termination, or trailer termination.
References: [Advisory](#) • [Commit](#)

Maven-org.bouncycastle:bcprov-jdk18on-1.84 (14 Results)

Package Name: org.bouncycastle:bcprov-jdk18on
Version: 1.84
Total Results: 3

Category: [CWE-354](#)
Total Results: 3

Result 1 of 3 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: 2pZ1NvCZZoy9nkf16HGyy/FSh9h4b5x9b7AP4Z0oLGs=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-12816
Description: In Bouncy Castle for Java before 1.85, IESEngine stream-mode MAC forgery via length-dependent KDF split. This issue also affects Bouncy Castle for Java LTS before 2.73.12.
References: [Advisory](#)

Result 2 of 3 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: ZdKfUTKtkYkqQK5QRpwVkrmiSwQCAwx0QI849qf/s4I=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-58061

Description: In Bouncy Castle for Java prior to 1.85, CCM-family modes write plaintext to caller buffer before tag check. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

References: [Advisory](#) [Disclosure](#) [Commit](#) [Commit](#)

Result 3 of 3 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: oqHvV6ExOEMMyr6QLb/wrQQpo3sW7zzr1isGTjxa/So=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-12803

Description: In Bouncy Castle for Java prior to 1.85, "KCCMBlockCipher" MAC does not bind nonce when AAD is absent (cross-nonce AEAD forgery). This issue also affects Bouncy Castle for Java LTS prior to 2.73.12.

References: [Advisory](#) [Disclosure](#) [Commit](#) [Commit](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-347](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: 5TR/OPHJwscDKEYVzWuL7vmhdQPdKmeBWNdkECK+qZE=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-12860

Description: In Bouncy Castle for Java before 1.85, RSA PKCS#1 verification skips last two hash bytes in NULL-omitted path. This issue also affects Bouncy Castle for Java LTS before 2.73.12.

References: [Advisory](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-674](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: bV2ILvqRFhmYUblnrj8w5v78+UCTXrsDhd8tFj9dtA=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-13506

Description: In Bouncy Castle for Java prior to 1.85, Lazy ASN.1 sequence forcing resets nesting-depth guard. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

References: [Advisory](#) [Disclosure](#) [Commit](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 2

Category: [CWE-789](#)

Total Results: 2

Result 1 of 2 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: NLGJr+XmMlyvPpod8Gln9YVoPzUNDquo9O7KTuZQgbE=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-14682

Description: In Bouncy Castle for Java prior to 1.85, Possible OOM from unbounded up-front allocation on a definite-length read. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series), and prior to bctls-fips 1.0.24 and 2.x prior to 2.1.24.

References: [Advisory](#) • [Disclosure](#) • [Commit](#)

Result 2 of 2 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: X+I08PuT1m4MpNJpCI74W2jjvt4mVNSEoKzMabsv1dw=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-58060

Description: In Bouncy Castle for Java prior to 1.85, HSS public-key level count unbounded, enabling huge allocation on verify. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bc-fips 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

References: [Advisory](#) • [Disclosure](#) • [Commit](#) • [Commit](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-407](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: JegKmb4q1wvH0ne4fEI0IO+eLPRokv9MN9fxsltZlB0=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-58059

Description: In Bouncy Castle for Java prior to 1.85, Quadratic-time escaping when stringifying X.500 distinguished names. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

References: [Advisory](#) • [Disclosure](#) • [Commit](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-834](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: d+shQmfJlnKko2Df5GLeoKjo1YwzYDuntG+m1wPU0pE=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59644

Description: In Bouncy Castle for Java before 1.85, MLS hash-ratchet honours arbitrary 32-bit generation counter from sender.

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-326](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: yXLR9Lf5b1/OfJKm1dk6Fgi0O1jdr4XTWaHwhq4FOAk=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59651

Description: In Bouncy Castle for Java prior to 1.85, BKS keystore accepts legacy version with 16-bit integrity MAC key. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12.

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 2

Category: [CWE-770](#)

Total Results: 2

Result 1 of 2 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: sKsqSesqHSY9SCldQaO5GRU+ZIIEOmTs2l/sgUV8d00=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-58063

Description: In Bouncy Castle for Java prior to 1.85, BCFKS keystore load honours unbounded KDF cost from an untrusted file. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Result 2 of 2 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: z/U1ve7Y0Fh2X7XlutrE5fDkBXVxb2J13l6vp52ds= • First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-13586

Description: In Bouncy Castle for Java before 1.85, PKCS#12 MAC and bag-decryption KDF iteration-count bound (DoS). This issue also affects Bouncy Castle for Java LTS before 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) before bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

References: [Advisory](#) • [Advisory](#) • [Commit](#) • [Commit](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-20](#)

Total Results: 1

Result 1 of 1 - Vulnerability

Critical • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: 2ZcJZhRb4IMCjnv6AaKDqf3/8yVv8T4necz7cxGjTT4=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: [CVE-2026-59650](#)

Description: In Bouncy Castle for Java before 1.85, MTI/AO DH agreement exponentiates unvalidated peer value.

This issue also affects Bouncy Castle for Java LTS before 2.73.12.

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Package Name: org.bouncycastle:bcprov-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-295](#)

Total Results: 1

Result 1 of 1 - Vulnerability

Critical • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: KiXjngh3cAD+q08ZfVvmDgv+TTjqhYTB9ArsCI7L/7A=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: [CVE-2026-8763](#)

Description: In Bouncy Castle for Java prior to 1.85, Name Constraints bypass via trailing dot in rfc822Name and URI. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Maven-tools.jackson.core:jackson-databind-3.2.1 (2 Results)

Package Name: tools.jackson.core:jackson-databind

Version: 3.2.1

Total Results: 1

Category: [CWE-400](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: no • Found First: 16 Sep, 2026

Result ID: Klmo50I1i4X76FAuD7fBKqva5yS7YNAeo+nX8BkqN1s=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-68497

Description: jackson-databind binds a JSON string to a `javax.xml.datatype.Duration` or `javax.xml.datatype.XMLGregorianCalendar` field by passing the raw string verbatim to `DatatypeFactory.newDuration(value)` or `newXMLGregorianCalendar(value)` in `CoreXMLDeserializers.Std._deserialize`. These deserializers are registered by default with no opt-in, so a plain `ObjectMapper` or `JsonMapper` with no polymorphic typing and no special configuration reaches this path. The XML Schema lexical grammar permits numeric components of arbitrary length, which the JDK materializes through the native `BigInteger(String)` and `BigDecimal(String)` constructors, both quadratic in digit count. Because the digits sit inside a JSON string token rather than a JSON number token, jackson-core's `StreamReadConstraints.maxNumberLength` guard never applies; jackson's own `NumberDeserializers` call `validateIntegerLength` or `validateFPLength` before parsing a stringified number, but the XML datatype deserializer omits that pre-check. An unauthenticated attacker can therefore submit a single request of a few megabytes, such as a `Duration` value consisting of the letter P followed by several million digits and the letter Y, and force tens of seconds to several minutes of single-threaded CPU work; a handful of concurrent requests can saturate a server's worker threads. This affects `com.fasterxml.jackson.core:jackson-databind` from 2.0.0 before 2.18.10, from 2.19.0 before 2.21.6, and from 2.22.0 before 2.22.2, and `tools.jackson.core:jackson-databind` from 3.0.0 before 3.1.6 and from 3.2.0 before 3.2.2. Users should upgrade to 2.18.10, 2.21.6, 2.22.2, 3.1.6, or 3.2.2.

References: [Advisory](#) [↗](#)

Package Name: `tools.jackson.core:jackson-databind`

Version: 3.2.1

Total Results: 1

Category: [CWE-470](#) [↗](#)

Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: no • Found First: 16 Sep, 2026

Result ID: `+xlrDYEMqk5+r7erUpRDlyuhju/TU4vznKYgv7XesLw=`

First Scan ID: `b60831d9-e7da-41dd-9da5-0d7827fc7374`

CVE: CVE-2026-19032

Description: jackson-databind's deserializer for `java.nio.file.Path` resolves an attacker-supplied URI without restricting the URI scheme. In `JDKFromStringDeserializer.NioPathHelper.deserialize`, a string bound from untrusted JSON is passed to `new URI(value)` and then to `Path.of(uri)`. When that throws `FileSystemNotFoundException`, the code enumerates `ServiceLoader<FileSystemProvider>` and calls `provider.getPath(uri)` on the first provider whose scheme matches the attacker-chosen scheme. Untrusted JSON can therefore select and drive an arbitrary registered `FileSystemProvider` during `readValue` under a default `JsonMapper`, and forces provider class loading at the same time. With only the JDK built-in providers (file, jar/zipfs) present, the resolved path is inert and no mount or network I/O occurs; further impact requires a side-effecting third-party `FileSystemProvider` on the `classpath`. This affects `com.fasterxml.jackson.core:jackson-databind` from 2.8.0 before 2.18.10, from 2.19.0 before 2.21.6, and from 2.22.0 before 2.22.2, and `tools.jackson.core:jackson-databind` from 3.0.0 before 3.1.6 and from 3.2.0 before 3.2.2. Users should upgrade to 2.18.10, 2.21.6, 2.22.2, 3.1.6, or 3.2.2. Binding `java.nio.file.Path` from untrusted JSON should be avoided regardless of version.

References: [Advisory](#) [↗](#)

Maven-commons-collections:commons-collections-3.2.2 (1 Result)

Package Name: `commons-collections:commons-collections`

Version: 3.2.2

Total Results: 1

Category: [CWE-674](#) [↗](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: n1S+xtiedQLRGY8f/TNY7vM6U1QvMb8WbYpe2K6ISHM=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: Cx78f40514-81ff

Description: The framework Apache Commons Collections before 4.3 is vulnerable to Stack Overflow. The function `add()` in the file `SetUniqueList.java` throws a StackOverflowError when the `add()` method is called with its own list. Please note: the package name was changed from "commons-collections:commons-collections" to "org.apache.commons:commons-collections4" on version 4.0.

References: [Issue](#) • [Pull request](#) • [Commit](#)

Maven-org.eclipse.jetty.websocket:jetty-websocket-core-common-12.1.11 (1 Result)

Package Name: org.eclipse.jetty.websocket:jetty-websocket-core-common

Version: 12.1.11

Total Results: 1

Category: [CWE-770](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: 7dpodh2sQZwnXU7kGwCwbVsgVc3A5vVrGbyJkKObEuM=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-19204

Description: A client may send a WebSocket frame with an unknown opcode and a very large declared payload length, causing Jetty to attempt a large memory allocation and potentially exhaust the JVM heap. This occurs when auto-fragmentation is enabled, as unknown opcodes bypass the normal maximum frame size handling and payload allocation occurs before the opcode is validated. All versions prior to 12.0.38 and 12.1.x prior to 12.1.12 are affected.

References: [Advisory](#) • [Commit](#)

Maven-org.springframework:spring-beans-7.0.8 (1 Result)

Package Name: org.springframework:spring-beans

Version: 7.0.8

Total Results: 1

Category: [CWE-400](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: no • Found First: 16 Sep, 2026
Result ID: nzDgExVljqOYcHNRfKGPM60RK8/5kLwM2/7mnTk6K+g=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59282

Description: Spring Framework applications that use Spring's data binding infrastructure to apply user-supplied property paths onto a target object may be vulnerable to a Denial-of-Service (DoS) attack. This issue affects Spring Framework versions through 5.2.25.RELEASE, 5.3.0 through 5.3.49, 6.0.0 through 6.0.30, 6.1.0 through 6.1.28, 6.2.0 through 6.2.19 and 7.0.0 through 7.0.8.

References: [Advisory](#) • [Advisory](#)

Maven-org.springframework:spring-expression-7.0.8 (2 Results)

Package Name: org.springframework:spring-expression
Version: 7.0.8
Total Results: 1

Category: [CWE-400](#)
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: no • Found First: 16 Sep, 2026
Result ID: IQmcBgNfeVLbUzNrfq8kl9iaHz1JlgtKyhHLG3SXAs=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-47886

Description: Applications that evaluate user-supplied Spring Expression Language (SpEL) expressions may be vulnerable to a Denial-of-Service (DoS) attack when the power operator (^) is used with a BigDecimal or BigInteger operand and a large exponent value. This issue affects Spring Framework versions from through 5.2.25.RELEASE, 5.3.0 through 5.3.49, 6.0.0 through 6.0.30, 6.1.0 through 6.1.28, 6.2.0 through 6.2.19 and 7.0.0 through 7.0.8.

References: [Advisory](#) • [Advisory](#)

Package Name: org.springframework:spring-expression
Version: 7.0.8
Total Results: 1

Category: [CWE-913](#)
Total Results: 1

Result 1 of 1 - Vulnerability
Critical • New • To Verify • Outdated: no • Found First: 16 Sep, 2026
Result ID: QXoy0Y3awS5i9o5ZJnE8cs9XUF80FW3L4zb2MCoMVko=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59283

Description: Applications that evaluate Spring Expression Language (SpEL) expressions using "SimpleEvaluationContext" may be vulnerable to a safety guard bypass when the SpEL expression compiler is active. This issue affects Spring Framework versions through 5.2.25.RELEASE, 5.3.0 through 5.3.49, 6.0.0 through 6.0.30, 6.1.0 through 6.1.28, 6.2.0 through 6.2.19 and 7.0.0 through 7.0.8.

References: [Advisory](#) • [Advisory](#)

Maven-org.springframework:spring-web-7.0.8 (2 Results)

Package Name: org.springframework:spring-web
Version: 7.0.8
Total Results: 1

Category: [CWE-1275](#)
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: no • Found First: 16 Sep, 2026
Result ID: mDrGTH+Mnx+I9NJKqmFI/92Ygp7JF/uUSQEFwk5s9bE=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-47889

Description: A WebFlux application running on the Jetty 12 Core reactive adapter serializes response cookies without the "sameSite" attribute. This issue affects Spring Framework versions from 6.2.0 through 6.2.19 and 7.0.0 through 7.0.8.

References: [Advisory](#) • [Advisory](#) • [Issue](#) • [Commit](#) • [Release Note](#)

Package Name: org.springframework:spring-web

Version: 7.0.8

Total Results: 1

Category: [CWE-79](#)

Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: no • Found First: 16 Sep, 2026

Result ID: UDCSO3hZBes/BAjLWRRisfmeNDfdBqkkPSyPxR4wZrk=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59281

Description: Spring MVC and WebFlux applications that obtain a data-binding Errors instance with HTML escaping enabled and then render field errors using the no-argument "Errors.getFieldErrors()" or "Errors.getFieldError()" accessors are vulnerable to arbitrary HTML/JavaScript code injection, potentially resulting in a reflected Cross-Site Scripting (XSS) vulnerability. This issue affects Spring Framework versions through 5.2.25.RELEASE, 5.3.0 through 5.3.49, 6.0.0 through 6.0.30, 6.1.0 through 6.1.28, 6.2.0 through 6.2.19 and 7.0.0 through 7.0.8.

References: [Advisory](#) • [Advisory](#) • [Issue](#) • [Commit](#)

Maven-org.apache.ant:ant-1.10.17 (1 Result)

Package Name: org.apache.ant:ant

Version: 1.10.17

Total Results: 1

Category: [CWE-23](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: Ho2l83650l0xaQJM8oZdLMSRWSOCE8UhDB3rPpXZopc=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-78254

Description: The ftp and scp tasks of Apache Ant can download files from a remote server. A malicious server can provide relative paths that allow it to write outside of the dedicated target directory for the download, making it possible to overwrite files of the attacker's choice using the permissions of the user running Ant in versions 1.2 prior to Ant 1.10.18. In order to exploit this vulnerability, the server would either have to be malicious or be subject to a machine-in-the-middle attack. Additionally in the case of scp or the ftp task using ftps the server must pass the server identity checks performed by the tasks. For ftp tasks not using ftps a malicious server could act as a machine-in-the-middle to provide malicious files. Starting with Ant 1.10.18 both tasks will prevent writing outside of the destination directory by default. An option is available to disable this behavior in the unlikely case that the old behavior is required by existing build files. Mitigations: Users of scp and ftp (when using ftps) in any version of Ant should not bypass server identity checks. Users of ftp not using ftps should switch to ftps where possible. All users are recommended to upgrade to Apache Ant 1.10.18, which fixes this issue.

References: [Advisory](#) • [Mail Thread](#)

Package Name: org.bouncycastle:bcpg-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-354](#)
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: /dJ7AzymrGp190giMmD+JjaYE2S7PPEEOiTr0+hNibk=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-12817
Description: In Bouncy Castle for Java prior to 1.85, OpenPGP AEAD decryption skips final tag on chunk-aligned data. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bcpg-fips 1.0.13 (1.0.X series), 2.0.13 (2.0.X series) and 2.1.13 (2.1.X series).
References: [Advisory](#) • [Disclosure](#) • [Commit](#)

Package Name: org.bouncycastle:bcpg-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-203](#)
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: vYXmppmhqFYCcRhk4WLW9w6dZW+UwqEApeqaJlqqlo=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59640
Description: In Bouncy Castle for Java prior to 1.85, OpenPGP CFB quick-check oracle is active on symmetric/session-key paths. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bcpg-fips 1.0.13 (1.0.X series), 2.0.13 (2.0.X series) and 2.1.13 (2.1.X series).
References: [Advisory](#) • [Advisory](#) • [Commit](#)

Package Name: org.bouncycastle:bcpg-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-347](#)
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: 3duvqVG4+EEKCcJ+pcv+QCwuQnWAQ4BEHaVJhXRAC58=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59643
Description: In Bouncy Castle for Java prior to 1.85, OpenPGP inline-signature policy failures are silently ignored. This issue also affects Bouncy Castle for Java FIPS (BC-FJA) prior to bcpg-fips 2.0.13.
References: [Advisory](#) • [Advisory](#) • [Commit](#)

Package Name: org.bouncycastle:bcpg-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-789](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: 2tmXX5LmspBkRGBk9YVGJ2qPtesRsStGd11oIO86Khg=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: [CVE-2026-59649](#)

Description: In Bouncy Castle for Java prior to 1.85, OpenPGP user-attribute subpacket length is bounded only by JVM maximum memory. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bcpg-fips 1.0.13 (1.0.X series), 2.0.13 (2.0.X series) and 2.1.13 (2.1.X series).

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Package Name: org.bouncycastle:bcpg-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-770](#)

Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: h8CWk/VGLs3Fd1d1RF+SBdKawb1/pgl/I+Qy0aFr+vo=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: [CVE-2026-59648](#)

Description: In Bouncy Castle for Java prior to 1.85, OpenPGP Argon2 S2K honours attacker-chosen memory and passes. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bcpg-fips 1.0.13 (1.0.X series), 2.0.13 (2.0.X series) and 2.1.13 (2.1.X series).

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Maven-org.bouncycastle:bcpkix-jdk18on-1.84 (6 Results)

Package Name: org.bouncycastle:bcpkix-jdk18on

Version: 1.84

Total Results: 2

Category: [CWE-354](#)

Total Results: 2

Result 1 of 2 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: Th+IYiOcr96/em02QLKa5hPKN+qdrEUek9ap4q+ygg=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: [CVE-2026-12802](#)

Description: In Bouncy Castle for Java before 1.85, CMS AuthEnvelopedData fails to enforce tag-length on decryption. This issue also affects Bouncy Castle for Java LTS before 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) before bcpkix-fips 1.0.12 (1.0.X series), 2.0.12 (2.0.X series) and 2.1.12 (2.1.X series).

References: [Advisory](#)

Result 2 of 2 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: G3JdrkR0Tulj1S/K08HN5++zcEE9fu1LBHmLLHLEIWU=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59642

Description: In Bouncy Castle for Java prior to 1.85, CMS AuthenticatedData content is not bound to the MAC when authAttrs are present. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bcpkix-fips 1.0.12 (1.0.X series), 2.0.12 (2.0.X series) and 2.1.12 (2.1.X series).

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Package Name: org.bouncycastle:bcpkix-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-347](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: MpFQ66pYcHWigA5mOaw0w737HAO2gbR3Cul9KfATISk=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59639

Description: In Bouncy Castle for Java prior to 1.85, CMS `verifySignatures` returns true for `SignedData` with zero signers. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to `bcpkix-fips` 1.0.12 (1.0.X series), 2.0.12 (2.0.X series), and 2.1.12 (2.1.X series).

References: [Advisory](#) • [Advisory](#) • [Commit](#)

Package Name: org.bouncycastle:bcpkix-jdk18on

Version: 1.84

Total Results: 1

Category: [CWE-674](#)

Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: IRM5GIfwnu4CykrewPDlj4YUOrlytBJ20Hbz3yzIm2s=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59645

Description: In Bouncy Castle for Java prior to 1.85, OER parser recurses without depth limit on self-referential IEEE 1609.2 schema. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bcutil-fips 2.0.7 (2.0.X series) and 2.1.7 (2.1.X series).

References: [Advisory](#) • [Disclosure](#) • [Commit](#)

Package Name: org.bouncycastle:bcpkix-jdk18on

Version: 1.84

Total Results: 2

Category: [CWE-770](#)
Total Results: 2

Result 1 of 2 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: EhTQB4Wv7KRAS74hef/4dXBTcMxA2E6l96drsXTVp4l=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59647
Description: In Bouncy Castle for Java prior to 1.85, CRMF/CMP password-MAC honours unbounded iteration count. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bcpkix-fips 1.0.12 (1.0.X series), 2.0.12 (2.0.X series) and 2.1.12 (2.1.X series).
References: [Advisory](#) • [Advisory](#) • [Commit](#)

Result 2 of 2 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026
Result ID: 6hPAYHZuTJm94IMmrqMVRHivcOHl7K5L1THba+IOeR4=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-15055
Description: In Bouncy Castle for Java prior to 1.85, PKCS#8 / PBES2 decryptors honour unbounded KDF cost from input. This issue also affects Bouncy Castle for Java LTS prior to 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) prior to bcpkix-fips 1.0.12 (1.0.X series), 2.0.12 (2.0.X series) and 2.1.12 (2.1.X series).
References: [Advisory](#) • [Advisory](#) • [Commit](#)

Maven-org.springframework.security:spring-security-core-7.1.0 (2 Results)

Package Name: org.springframework.security:spring-security-core
Version: 7.1.0
Total Results: 1

Category: [CWE-693](#)
Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: no • Found First: 16 Sep, 2026
Result ID: eWuszt8RObToE7TSTX9+dwBvV75whRXvaZCYgfGmxBQ=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59277
Description: Spring Security's "InetAddressMatchers" utility provides "matchInternal()" and "matchExternal()" builders for constructing an "InetAddressMatcher" that classifies a given IP address as belonging to an internal (private) or external (public) network. This issue affects Spring Security version 7.1.0.
References: [Advisory](#) • [Advisory](#)

Package Name: org.springframework.security:spring-security-core
Version: 7.1.0
Total Results: 1

Category: [CWE-208](#)
Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: no • Found First: 16 Sep, 2026
Result ID: nNLwaNy8EyZ5WoK7aKU6W1ytfE5fUoF1oqRtsOaiZzw=
First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-59276

Description: Several components in Spring Security compare security-sensitive values using standard string equality "String.equals()" rather than a constant-time comparison. Because "String.equals()" returns as soon as it finds a differing character, the time taken to reject an incorrect value is proportional to the number of leading characters that match the expected value. This issue affects Spring Security versions from 5.7.0 through 5.7.25, 5.8.0 through 5.8.27, 6.4.0 through 6.4.18, 6.5.0 through 6.5.11, 7.0.0 through 7.0.6 and 7.1.0.

References: [Advisory](#) • [Advisory](#)

Maven-org.springframework.security:spring-security-crypto-7.1.0 (1 Result)

Package Name: org.springframework.security:spring-security-crypto

Version: 7.1.0

Total Results: 1

Category: [CWE-326](#)

Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: no • Found First: 16 Sep, 2026

Result ID: jZ11pZNU+au3z+CMewNYhs7EWDGB38YivvxS/8HHXq8=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2026-47842

Description: Applications using AesBytesEncryptor with the two-argument constructor or when passing a null IV generator and CBC as the encryption mode encrypt data with AES/CBC using a null (all-zero) initialization vector. This issue affects Spring Security versions from 5.7.0 through 5.7.25, 5.8.0 through 5.8.27, 6.4.0 through 6.4.18, 6.5.0 through 6.5.11, 7.0.0 through 7.0.6 and 7.1.0.

References: [Advisory](#) • [Advisory](#)

Maven-commons-lang:commons-lang-2.6 (1 Result)

Package Name: commons-lang:commons-lang

Version: 2.6

Total Results: 1

Category: [CWE-674](#)

Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 16 Sep, 2026

Result ID: b0DWLQv6iZ8ppK7+X227CbM16GPYghhti3h602E9eZM=

First Scan ID: b60831d9-e7da-41dd-9da5-0d7827fc7374

CVE: CVE-2025-48924

Description: Uncontrolled Recursion vulnerability in Apache Commons Lang. The methods `ClassUtils.getClass(...)` can `throwStackOverflowError` on very long inputs. Because an error is usually not handled by applications and libraries, a `StackOverflowError` could cause an application to stop. Users are recommended to upgrade to version 3.18.0, which fixes the issue. This issue affects commons-lang:commons-lang versions 2.0 through 2.6, and org.apache.commons:commons-lang3 versions 3.0 through 3.17.0.

References: [Advisory](#) • [Mail Thread](#) • [Commit](#) • [Release Note](#)

SAST Resolved Vulnerabilities

No data to show

Categories

ASA Premium

Category			
ASA Premium	1	2	2

ASD STIG 6.1

Category			
APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting (XSS) vulnerabilities.	1	0	0
APSC-DV-002460 - CAT II The application must maintain the confidentiality and integrity of information during preparation for transmission.	0	2	0

Base Preset

Category			
Base Preset	1	0	2

CWE top 25

Category			
CWE top 25	1	0	1

FISMA 2014

Category			
System And Information Integrity	1	0	0
Configuration Management	0	2	0

MOIS(KISA) Secure Coding 2021

Category			
MOIS(KISA) Verification and representation of input data	1	0	1

MOIS(KISA) Security Functions	0	2	0
-------------------------------	---	---	---

NIST SP 800-53			
Category	C	H	M
SI-15 Information Output Filtering (P0)	1	0	0
SC-8 Transmission Confidentiality and Integrity (P1)	0	2	0

OWASP ASVS			
Category	C	H	M
V05 Validation, Sanitization and Encoding	1	0	0
V09 Communication	0	2	0
V12 Files and Resources	0	0	1
V14 Configuration	0	0	2

OWASP Mobile Top 10 2024			
Category	C	H	M
M4: Insufficient Input/Output Validation	1	0	1
M5: Insecure Communication	0	2	0

OWASP Top 10 2013			
Category	C	H	M
A3-Cross-Site Scripting (XSS)	1	0	0
A6-Sensitive Data Exposure	0	2	0
A4-Insecure Direct Object References	0	0	1

A4-Insecure Direct Object References	0	0	1
--------------------------------------	---	---	---

OWASP Top 10 2017

Category			
A5-Broken Access Control	0	0	1
A7-Cross-Site Scripting (XSS)	1	0	0
A3-Sensitive Data Exposure	0	2	0

OWASP Top 10 2021

Category			
A3-Injection	1	0	1
A2-Cryptographic Failures	0	2	0
A1-Broken Access Control	0	0	1
A7-Identification and Authentication Failures	0	0	2

OWASP Top 10 2025

Category			
A05-Injection	1	0	0
A04-Cryptographic Failures	0	2	0
A01-Broken Access Control	0	0	1
A07-Authentication Failures	0	0	2

OWASP Top 10 API

Category			
API7-Security Misconfiguration	0	2	0

OWASP Top 10 API 2023

Category			
API10-Unsafe Consumption of APIs	0	2	0
API4-Unrestricted Resource Consumption	0	0	2
API8-Security Misconfiguration	0	0	1

PCI DSS v3.2.1

Category			
PCI DSS (3.2.1) - 6.5.4 - Insecure communications	0	2	0
PCI DSS (3.2.1) - 6.5.8 - Improper access control	0	0	1
PCI DSS (3.2.1) - 6.5.7 - Cross-site scripting (XSS)	1	0	0

PCI DSS v4.0

Category			
PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development	1	2	3

SANS top 25

Category			
SANS top 25	1	2	1

Top Tier			
Category			
Top Tier	1	0	0

Stored_XSS (CWE 79)**What Is The Risk**

A successful XSS exploit would allow an attacker to rewrite web pages and insert malicious scripts which would alter the intended output. This could include HTML fragments, CSS styling rules, arbitrary JavaScript, or references to third party code. An attacker could use this to steal users' passwords, collect personal data such as credit card details, provide false information, or run malware. From the victim's point of view, this is performed by the genuine website, and the victim would blame the site for incurred damage. An attacker could use legitimate access to the application to submit modified data to the application's data-store. This would then be used to construct the returned web page, triggering the attack.

What Can Cause It

The application creates web pages that include untrusted data, whether from user input, the application's database, or from other external sources. The untrusted data is embedded directly in the page's HTML, causing the browser to display it as part of the web page. If the input includes HTML fragments or JavaScript, these are displayed too, and the user cannot tell that this is not the intended page. The vulnerability is the result of directly embedding arbitrary data without first encoding it in a format that would prevent the browser from treating it like HTML or code instead of plain text. In order to exploit this vulnerability, an attacker would load the malicious payload into the data-store, typically via regular forms on other web pages. Afterwards, the application reads this data from the data-store, and embeds it within the web page as displayed for another user.

General Recommendations

- * Fully encode all dynamic data, regardless of source, before embedding it in output.
- * Encoding should be context-sensitive. For example:
 - * HTML encoding for HTML content
 - * HTML Attribute encoding for data output to attribute values
 - * JavaScript encoding for server-generated JavaScript
- * It is recommended to use the platform-provided encoding functionality, or known security libraries for encoding output.
- * Implement a Content Security Policy (CSP) with explicit whitelists for the application's resources only.
- * As an extra layer of protection, validate all untrusted data, regardless of source (note this is not a replacement for encoding). Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
 - * Data type
 - * Size
 - * Range
 - * Format
 - * Expected values
- * In the `Content-Type` HTTP response header, explicitly define character encoding (charset) for the entire page.
- * Set the `HTTPOnly` flag on the session cookie for "Defense in Depth", to prevent any successful XSS exploits from stealing the cookie.

Cleartext_Submission_of_Sensitive_Information (CWE 319)**What Is The Risk**

Sensitive and personal details, such as passwords, social security numbers, credit card data, and other forms of PII (Personally Identifiable Information), must always be protected when being transmitted over the network. Sending this private data over an unencrypted channel, such as without using SSL/TLS or other form of encryption, can reveal the users' secret information and expose them to risks of impersonation, identity theft, and financial fraud. If the SSL/TLS channel is terminated on a front-end webserver, reverse proxy, or the like, this issue can be ignored.

What Can Cause It

The application handles sensitive and private information in several ways. At a certain point, this secret data is sent over the network, however the application does not use SSL/TLS, or any other secure protocol, and does not ensure the data is encrypted before sending it over the unprotected channel.

General Recommendations

- * Always protect all PII and other sensitive data, especially when it is being sent over the network.
- * Use SSL/TLS whenever transmitting sensitive data. Alternatively, other encrypted protocols, such as IPsec or SSH, can also be used.
- * Reconsider if the application absolutely requires these personal details. Data that is not received cannot be exposed.
- * In web applications, do not output personal info directly to the response without verifying the channel is secured.
- * Do not write personal info directly to a standard socket either. Instead, always use SSLSocket to ensure your channel makes use of SSL/TLS.

Uncontrolled_Memory_Allocation (CWE 789)

What Is The Risk

Allowing an untrusted user to control the amount of memory allocated in the application could allow an attacker to increase memory consumption arbitrarily, eventually causing out-of-memory errors in the application or possibly even crashing the server, causing a DoS (Denial of Service) attack.

What Can Cause It

The application declares and instantiates a large object, representing a data structure containing a collection of a given type of object. The size of the collection, and the number of elements contained in it, is initially set when constructing the object. However, the application sets the initial capacity based on external, untrusted user input, e.g. via the size of data or even as an explicit value.

General Recommendations

- Do not allow untrusted users to control memory allocation.
- Avoid instantiating collection objects based on external user input, if possible.
- If necessary, validate all input before instantiating a collection based on the value or size of data.
- In particular, constrain the maximum size of the initial capacity of the collection to a sane default.
- Ensure the application fails securely even in limited memory scenarios.

Stored_Absolute_Path_Traversal (CWE 36)

What Is The Risk

An attacker could define arbitrary file path for the application to use, potentially leading to: * Stealing sensitive files, such as configuration or system files * Overwriting files such as program binaries, configuration files, or system files * Deleting critical files, causing denial of service (DoS).

What Can Cause It

The application relies on data from storage to determine the file path for accessing files on the application server's local disk. If this data can be tainted by user input, an attacker may store their own value to perform path traversal via the vulnerable method.

General Recommendations

1. Ideally, avoid depending on dynamic data for file selection.
2. Validate all input, regardless of source. Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
 - * Data type
 - * Size
 - * Range
 - * Format
 - * Expected values
4. Accept dynamic data only for the filename, not for the path and folders.
5. Ensure that file path is fully canonicalized.
6. Explicitly limit the application to use a designated folder that is separate from the applications binary folder.
7. Restrict the privileges of the application's OS user to necessary files and folders. The application should not be able to write to the application binary folder, and should not read anything outside of the application folder and data folder.

Missing_HSTS_Header (CWE 346)

What Is The Risk

Failure to set an HSTS header and provide it with a reasonable "max-age" value of at least one year may leave users vulnerable to Man-in-the-Middle attacks.

What Can Cause It

Many users browse to websites by simply typing the domain name into the address bar, without the protocol prefix. The browser will automatically assume that the user's intended protocol is HTTP, instead of the encrypted HTTPS protocol. When this initial request is made, an attacker can perform a Man-in-the-Middle attack and manipulate it to redirect users to a malicious web-site of the attacker's choosing. To protect the user from such an occurrence, the HTTP Strict Transport Security (HSTS) header instructs the user's browser to disallow use of an unsecure HTTP connection to the the domain associated with the HSTS header. Once a browser that supports the HSTS feature has visited a web-site and the header was set, it will no longer allow communicating with the domain over an HTTP connection. Once an HSTS header was issued for a specific website, the browser is also instructed to prevent users from manually overriding and accepting an untrusted SSL certificate for as long as the "max-age" value still applies. The recommended "max-age" value is for at least one year in seconds, or 31536000.

General Recommendations

- * Before setting the HSTS header - consider the implications it may have:
 - * Forcing HTTPS will prevent any future use of HTTP, which could hinder some testing
 - * Disabling HSTS is not trivial, as once it is disabled on the site, it must also be disabled on the browser
- * Set the HSTS header either explicitly within application code, or using web-server configurations.
- * Ensure the "max-age" value for HSTS headers is set to 31536000 to ensure HSTS is strictly enforced for at least one year.
- * Include the "includeSubDomains" to maximize HSTS coverage, and ensure HSTS is enforced on all sub-domains under the current domain
 - * Note that this may prevent secure browser access to any sub-domains that utilize HTTP; however, use of HTTP is very severe and highly discouraged, even for websites that do not contain any sensitive information, as their contents can still be tampered via Man-in-the-Middle attacks to phish users under the HTTP domain.
- * Once HSTS has been enforced, submit the web-application's address to an HSTS preload list - this will ensure that, even if a client is accessing the web-application for the first time (implying HSTS has not yet been set by the web-application), a browser that respects the HSTS preload list would still treat the web-application as if it had already issued an HSTS header. Note that this requires the server to have a trusted SSL certificate, and issue an HSTS header with a maxAge of 1 year (31536000)
- * Note that this query is designed to return one result per application. This means that if more than one vulnerable response without an HSTS header is identified, only the first identified instance of this issue will be highlighted as a result. If a misconfigured instance of HSTS is identified (has a short lifespan, or is missing the "includeSubDomains" flag), that result will be flagged. Since HSTS is required to be enforced across the entire application to be considered a secure deployment of HSTS functionality, fixing this issue only where the query highlights this result is likely to produce subsequent results in other sections of the application; therefore, when adding this header via code, ensure it is uniformly deployed across the entire application. If this header is added via configuration, ensure that this configuration applies to the entire application.
- * Note that misconfigured HSTS headers that do not contain the recommended max-age value of at least one year or the "includeSubDomains" flag will still return a result for a missing HSTS header.

Missing_HSTS_Header (CWE 346)

What Is The Risk

Failure to set an HSTS header and provide it with a reasonable "max-age" value of at least one year may leave users vulnerable to Man-in-the-Middle attacks.

What Can Cause It

Many users browse to websites by simply typing the domain name into the address bar, without the protocol prefix. The browser will automatically assume that the user's intended protocol is HTTP, instead of the encrypted HTTPS protocol. When this initial request is made, an attacker can perform a Man-in-the-Middle attack and manipulate it to redirect users to a malicious web-site of the attacker's choosing. To protect the user from such an occurrence, the HTTP Strict Transport Security (HSTS) header instructs the user's browser to disallow use of an unsecure HTTP connection to the the domain associated with the HSTS header. Once a browser that supports the HSTS feature has visited a web-site and the header was set, it will no longer allow communicating with the domain over an HTTP connection. Once an HSTS header was issued for a specific website, the browser is also instructed to prevent users from manually overriding and accepting an untrusted SSL certificate for as long as the "max-age" value still applies. The recommended "max-age" value is for at least one year in seconds, or 31536000.

General Recommendations

- * Before setting the HSTS header - consider the implications it may have:
 - * Forcing HTTPS will prevent any future use of HTTP, which could hinder some testing
 - * Disabling HSTS is not trivial, as once it is disabled on the site, it must also be disabled on the browser
- * Set the HSTS header either explicitly within application code, or using web-server configurations.
- * Ensure the "max-age" value for HSTS headers is set to 31536000 to ensure HSTS is strictly enforced for at least one year.
- * Include the "includeSubDomains" to maximize HSTS coverage, and ensure HSTS is enforced on all sub-domains under the current domain
 - * Note that this may prevent secure browser access to any sub-domains that utilize HTTP; however, use of HTTP is very severe and highly discouraged, even for websites that do not contain any sensitive information, as their contents can still be tampered via Man-in-the-Middle attacks to phish users under the HTTP domain.
- * Once HSTS has been enforced, submit the web-application's address to an HSTS preload list - this will ensure that, even if a client is accessing the web-application for the first time (implying HSTS has not yet been set by the web-application), a browser that respects the HSTS preload list would still treat the web-application as if it had already issued an HSTS header. Note that this requires the server to have a trusted SSL certificate, and issue an HSTS header with a maxAge of 1 year (31536000)
- * Note that this query is designed to return one result per application. This means that if more than one vulnerable response without an HSTS header is identified, only the first identified instance of this issue will be highlighted as a result. If a misconfigured instance of HSTS is identified (has a short lifespan, or is missing the "includeSubDomains" flag), that result will be flagged. Since HSTS is required to be enforced across the entire application to be considered a secure deployment of HSTS functionality, fixing this issue only where the query highlights this result is likely to produce subsequent results in other sections of the application; therefore, when adding this header via code, ensure it is uniformly deployed across the entire application. If this header is added via configuration, ensure that this configuration applies to the entire application.
- * Note that misconfigured HSTS headers that do not contain the recommended max-age value of at least one year or the "includeSubDomains" flag will still return a result for a missing HSTS header.